

**Assignment title: Comparative Incident & Security Breach
Analysis**

On

MGM Resorts and Change Healthcare

Prepare By: JOY ORILADE

Student ID: 2025/GCR/12719

**Course: GRC104 - Compliance Frameworks and Legal
Requirements**

Instructor: Comm. Idris Aminu

Date: 5th May 2026

Executive summary:

This report analyzes two major cybersecurity incidents. The MGM Resorts international which occurred in September 2023 and was social engineering /identity compromise (a ransomware attack) and the Change Health occurred in February 2024 and was a cyber offensive attack with a systematic risk in critical infrastructure and third-party dependencies.

The failure in both incidents revealed identity security, monitoring and incident response readiness with operational disruption and reputational damage to it organization

The MGM Resorts incident indicates the dangers of vishing and identity-based attack against the IT help desk to gain unauthorized access to internal systems. The cyberattack was allegedly carried out by the scattered spider threat group. The attack disrupted hotel operations, digital room keys, slot machines, payment, and online booking services.

The Change Health incidents indicate the dangers of ransomware attacked linked to the ALPHV/BlackCat ransomware group. The attack disrupted healthcare payment processing, pharmacy operations, insurance claims, and medical services across the United States.

Incident response A: The MGM Resorts international which occurred in September 2023

1. The affected organization (industry, size, and geographic location)

ANSWER

Industry: Hospitality and Entertainment

Size: 75,000 employees

Geographic Location: Las Vegas, NV USA

2. The type of incident (data breach, ransomware, insider misuse, supply-chain compromise, etc.)

ANSWER

Ransomware and Data breach

3. The security requirements and regulations relevant to that organization (examples: GDPR, HIPAA, PCI-DSS, SOX, local financial regulations, data localization laws)

ANSWER:

- **PCI-DSS:** Strict requirements for protecting cardholder data across casino and hotel properties.
- **GDPR:** Relevant due to European guests and global operations.
- **SEC Cyber Disclosure Rules:** Requirements for reporting material incidents within 4 business days.
- **Nevada Gaming Control Board Regulations:** Stringent cybersecurity standards for licensed gaming operators.

4. The root causes and control failures that enabled the incident (technical, process, and human factors)

ANSWER

- **Human Factor:** Sophisticated social engineering. An attacker found an employee's name on LinkedIn and called the IT help desk to request a password reset, bypassing MFA.
- **Technical Factor:** Lack of "Zero Trust" architecture. Once the attacker gained initial access to an administrative account, they were able to move laterally through the Okta environment.
- **Process Factor:** Inadequate verification protocols for identity management at the help desk level.

5. The detection and disclosure timeline (who discovered the incident and how; self-reported vs discovered by regulator/third-party)

ANSWER

Detection: September 10, 2023. Noticed internally as systems began to fail.

Disclosure: Self-reported via social media and SEC filings shortly after detection.

6. The organizational and regulatory response (notifications, remediation, fines, litigation, executive consequences)

ANSWER

1. Notification:

- MGM publicly confirmed the cyberattack after systems and hotel operations were disrupted.
- Customers were informed about potential exposure of personal information.
- Relevant authorities and regulators were notified in line with applicable data protection and disclosure requirements.

2. Remediation:

- Shut down affected systems to prevent further unauthorized access.
- Engaged third-party cybersecurity firms for forensic investigation and recovery.
- Reset employee credentials and strengthened identity verification procedures.
- Improved help desk authentication processes to reduce social engineering risks.
- Enhanced monitoring and incident response capabilities.

3. Fines and Litigation:

- MGM faced potential legal claims from affected customers and shareholders.
- Regulatory scrutiny increased regarding cybersecurity disclosures and customer data protection.
- Significant financial losses occurred due to operational downtime and remediation expenses.

4. Executive Consequences:

- Executives faced pressure from investors and the public over cybersecurity governance weaknesses.
- The incident increased demand for stronger executive accountability and board involvement in cyber risk management.

7. Impact assessment (data exposure, financial, reputational, operational, customer trust)

ANSWER

Operational: Disrupted the US healthcare system for weeks; providers could not bill for services or verify insurance.

Financial: UHG paid an estimated \$22M ransom (confirmed by CEO testimony); total recovery costs exceeded \$800M.

Data Exposure: Sensitive PHI for a "substantial proportion of people in America" was likely exfiltrated.

8. Lessons learned & prioritized remediation roadmap (short, medium, long-term controls; policy and governance changes)

ANSWER

Lessons Learned

- Human-focused attacks such as social engineering remain highly effective.
- Help desk and identity verification processes are critical security control points.
- Organizations require faster incident detection and response capabilities.
- Cybersecurity awareness training is essential for all employees.

Prioritized Remediation

Timeline	Remediation Action	Priority
Short Term	Strengthen help desk authentication procedures, reset compromised accounts and credentials	High
Medium Term	Implement privileged access management and conduct organization wide phishing and social engineering training	Medium/High
Long Term	Increase board-level cybersecurity governance involvement, improve incident response and threat hunting capabilities and adopt zero trust security architecture	Medium/High

Policy and Governance Changes

- Updated identity verification policies
- Stronger access control governance
- Improved employee security awareness programs
- Enhanced incident reporting and escalation procedures

9. Individual accountability and criminal exposure considerations, including the role of whistleblowers and protections where relevant

ANSWER

Individual accountability

- Help desk personnel involved in identity verification failures may receive additional scrutiny or retraining.

- Executives and cybersecurity managers may face criticism for insufficient social engineering defenses.

Criminal exposure

- The attackers involved in unauthorized system access may face criminal prosecution for cybercrime, fraud, and extortion-related offenses.
- Any insider involvement could lead to severe legal and disciplinary consequences.

Whistleblowers and protections

- Employees should have secure channels to report suspicious activities or security gaps without fear of retaliation.
- Strong whistleblower policies help organizations identify internal weaknesses before they result in major incidents.

Incident response B: Change Healthcare (February 2024)

1. The affected organization (industry, size, and geographic location)

ANSWER

Industry: Healthcare Information Technology (Subsidiary of UnitedHealth Group).

Size: Processes 15 billion transactions annually (1 in 3 US patient records).

Location: USA

2. The type of incident (data breach, ransomware, insider misuse, supply-chain compromise, etc.)

ANSWER

Ransomware/Supply-Chain Compromise. Attributed to the BlackCat/ALPHV ransomware group.

3. The security requirements and regulations relevant to that organization (examples: GDPR, HIPAA, PCI-DSS, SOX, local financial regulations, data localization laws)

ANSWER

- **HIPAA:** Federal standards for protecting sensitive patient data (PHI).
- **SOX:** Financial reporting integrity requirements for the parent company (UHG).

4. The root causes and control failures that enabled the incident (technical, process, and human factors)

ANSWER

- **Technical Factor:** Lack of Multi-Factor Authentication (MFA) on a critical Citrix remote access portal.
- **Process Factor:** Inadequate segmentation of legacy systems inherited through acquisitions.
- **Human Factor:** Credential theft/compromise allowed for initial entry.

5. The detection and disclosure timeline (who discovered the incident and how; self-reported vs discovered by regulator/third-party)

ANSWER

- **Detection:** February 21, 2024.
- **Disclosure:** UHG disclosed the "cybersecurity issue" to the SEC and the public on the same day.

6. The organizational and regulatory response (notifications, remediation, fines, litigation, executive consequences)

ANSWER

Notification:

- The organization publicly disclosed the incident after detecting suspicious activities within its network.
- Customers, healthcare providers, pharmacies, and regulatory authorities were notified about the disruption and possible data exposure.
- Notifications were issued in compliance with HIPAA breach notification requirements and state data protection laws.

Remediation Action

- Disconnected affected systems from the network to contain the ransomware spread.
- Engaged external cybersecurity experts and incident response teams.
- Restored systems gradually and implemented stronger identity and access management controls.
- Enforced Multi-Factor Authentication (MFA) across critical systems.
- Increased monitoring and threat detection capabilities.

Fines and Litigation

- The organization faced multiple lawsuits related to data privacy violations and operational disruptions.
- Regulatory investigations were initiated concerning compliance with HIPAA and healthcare data protection requirements.
- Financial losses included recovery costs, ransom payments, legal fees, and business interruption expenses.

Executive Consequences

- Senior leadership faced public criticism over cybersecurity preparedness.
- Increased board-level oversight of cybersecurity governance.
- Executives were required to provide explanations to regulators and stakeholders regarding security failures and response actions.

7. Impact assessment (data exposure, financial, reputational, operational, customer trust)

ANSWER

- **Operational:** Disrupted the US healthcare system for weeks; providers could not bill for services or verify insurance.
- **Financial:** UHG paid an estimated \$22M ransom (confirmed by CEO testimony); total recovery costs exceeded \$800M.
- **Data Exposure:** Sensitive PHI for a substantial proportion of people in America was likely Exfiltrated.

8. Lessons learned & prioritized remediation roadmap (short, medium, long-term controls; policy and governance changes).

ANSWER

Lesson Learned

- Weak access controls can expose critical infrastructure to ransomware attacks.
- Healthcare organizations require stronger business continuity and disaster recovery capabilities.
- Cybersecurity governance must be integrated into executive decision-making.
- Third-party and supply chain dependencies increase organizational risk exposure.

Prioritized Remediation roadmap

Timeline	Remediation Action	Priority
Short Term	Enforce MFA on all system and conduct enterprise wide password reset	High
Medium Term	Deployed advanced endpoint detection and response tools and improve employee cybersecurity awareness training	High/Medium
Long Term	Conduct regular penetration testing and risk assessments and strengthen governance, risk and compliance program	Medium/High

Policy and Governance

- Stronger identity and access management policies
- Improved incident response procedures
- Enhanced vendor risk management framework
- Increased executive and board oversight of cybersecurity risk

9. Individual accountability and criminal exposure considerations, including the role of whistleblowers and protections where relevant

ANSWER

Individual accountability

- Security and IT leadership may face scrutiny for failing to enforce adequate cybersecurity controls.
- Employees responsible for maintaining critical access systems could be investigated internally if negligence contributed to the incident.

Criminal exposure

- Threat actors involved in the ransomware operation may face criminal prosecution under cybercrime laws.
- If evidence of deliberate negligence, concealment, or false reporting existed, executives could potentially face regulatory penalties or legal consequences.

Whistleblower Considerations

- Employees who report cybersecurity weaknesses internally should be protected from retaliation.
- Whistleblower protections encourage early reporting of security concerns and compliance failures.
- Regulatory frameworks often support employees who disclose organizational misconduct in good faith.

C. Comparative Analysis

Area	MGM Resorts	Change Healthcare
Industry	Hospitality	Healthcare
Attack Method	Social Engineering	Ransomware
Sensitive Data	Customer and Payment Data	Patient/Medical Data
Compliance Focus	PCI-DSS/SEC	HIPAA
Operational Impact	Resort and casino disruptions	Healthcare disruptions
Governance Weakness	Weak help IT desk verification	Weak MFA
Public Attention	Very High	Very High

D. References & appendices (timelines, supporting documents, source links)

- U.S. Securities and Exchange Commission (SEC) - Form 8-K Filings for MGM Resorts (Sept 2023) and UnitedHealth Group (Feb 2024).

https://www.sec.gov/Archives/edgar/data/789570/000119312523233855/d502352dex991.htm?utm_source=chatgpt.com

https://coursera-assessments.s3.amazonaws.com/assessments/1728158672868/8430c725-a8c6-496b-bd51-292b4fc51b45/Case%20Study-%20MGM%20Data%20Breach%202023.pdf?utm_source=chatgpt.com

- HHS Office for Civil Rights (OCR) - Investigation Notice regarding Change Healthcare.
<https://www.hipaajournal.com/ocr-opens-hipaa-compliance-investigation-of-change-healthcare/>
<https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html>
<https://www.ropesgray.com/en/insights/alerts/2024/04/change-healthcare-cyberattack-hhs-ocr-publishes-early-guidance-on-breach-and-unitedhealth-group>